

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Grant-Issuance Audit Template

Audit every grant in your fleet: capability, scope, issuer, expiry -- and flag the permanent ones. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

GRANT-ISSUANCE AUDIT TEMPLATE

For AI Agents in Production Environments Version 1.0 | [EFFECTIVE DATE] Prepared for: [ORGANIZATION NAME] Prepared by: [AUDIT TEAM NAME]

1. EXECUTIVE SUMMARY

This template provides a structured audit framework for evaluating the governance, compliance, and operational integrity of AI agent grants in production. It ensures alignment with organizational risk policies, cost controls, and incident response protocols.

Scope: - Applies to all AI agents granted access to [ORGANIZATION NAME]'s systems, data, or external APIs. - Covers initial grant issuance, ongoing monitoring, and revocation processes.

Key Focus Areas: 1. **Policy & Compliance Gates** - Alignment with internal policies and external regulations. 2. **Permissioning & Access Controls** - Role-based access, least privilege, and audit trails. 3. **Cost & Resource Governance** - Budget tracking, usage limits, and cost alerts. 4. **Incident Response & Containment** - Playbooks for breaches, misalignments, or unauthorized actions. 5. **Agent Lifecycle Management** - Onboarding, deprecation, and audit logging.

2. AUDIT CHECKLIST

2.1 POLICY & COMPLIANCE GATES

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.1.1	Grant aligns with [ORGANIZATION NAME]'s AI Governance Policy ([POLICY DOCUMENT LINK])	Signed acknowledgment or policy version check	[PASS/FAIL]	Verify [REQUESTER'S MANAGER] approved the grant per policy.
2.1.2	Agent complies with GDPR/CCPA/Other Applicable Laws (if handling PII)	Data processing agreement (DPA) or legal review stamp	[PASS/FAIL]	Attach DPA if applicable.
2.1.3	Grant includes explicit use-case justification (e.g., "Customer support automation")	[USE-CASE DESCRIPTION]	[PASS/FAIL]	Must align with [ORGANIZATION NAME]'s approved AI initiatives.
2.1.4	Third-party vendor risks assessed (if using external AI services)	Vendor risk assessment (VRA) or contract clause review	[PASS/FAIL]	Attach VRA if using [EXTERNAL AI PROVIDER].

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.1.5	Bias & Fairness Review conducted (if agent impacts decisions)	Bias audit report or mitigation plan	[PASS/FAIL]	Required for [AGENT_TYPE] (e.g., hiring tool, loan approval).

2.2 PERMISSIONING & ACCESS CONTROLS

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.2.1	Least-privilege principle enforced	Role-based access control (RBAC) matrix	[PASS/FAIL]	Agent role: [AGENT_ROLE], permissions: [PERMISSION_LIST].
2.2.2	Audit logs enabled for all agent actions	Sample log snippet or logging policy reference	[PASS/FAIL]	Logs must include [TIMESTAMP, USER, ACTION, RESOURCE].
2.2.3	Multi-factor authentication (MFA) required for agent admin access	MFA enforcement setting	[PASS/FAIL]	Applies to [ADMINISTRATOR_ROLE].
2.2.4	Grant expiration date set (max [MAX_GRANT_DURATION] days)	[GRANT_EXPIRY_DATE]	[PASS/FAIL]	Auto-revocation enabled? [YES/NO]
2.2.5	Manual revocation process documented	Revocation procedure (e.g., [REVOCATION_PROTOCOL])	[PASS/FAIL]	Tested in [TEST_DATE].

2.3 COST & RESOURCE GOVERNANCE

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.3.1	Budget allocation approved by [FINANCE TEAM]	Budget approval (e.g., [BUDGET_APPROVAL_ID])	[PASS/FAIL]	Allocated: [\${BUDGET_AMOUNT}].

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.3.2	Cost alert threshold set (e.g., 20% over budget)	[COST_ALERT_THRESHOLD]%	[PASS/FAIL]	Alerts sent to: [ALERT_CONTACT_EMAIL].
2.3.3	Usage quotas enforced (e.g., API calls/day)	[QUOTA_LIMIT] calls/day	[PASS/FAIL]	Enforcement method: [METHOD] (e.g., rate-limiting)].
2.3.4	Vendor cost reconciliation process in place	Monthly cost report template	[PASS/FAIL]	Owner: [COST_OWNER].
2.3.5	Cost recovery mechanism defined (if agent generates revenue)	[RECOVERY_METHOD] (e.g., 10% of savings)	[PASS/FAIL]	Approved by: [FINANCE_APPROVER].

2.4 INCIDENT RESPONSE & CONTAINMENT

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.4.1	Incident response playbook exists for agent failures	[PLAYBOOK_LINK]	[PASS/FAIL]	Includes steps for [SCENARIO] (e.g., data leak)].
2.4.2	Containment actions defined (e.g., revoke API keys)	[CONTAINMENT_PROCEDURE]	[PASS/FAIL]	Tested in [TEST_DATE].
2.4.3	Post-incident review required	Sample review template	[PASS/FAIL]	Owner: [INCIDENT_REVIEWER].
2.4.4	Escalation path documented for critical failures	Escalation matrix (e.g., [ESCALATION_MATRIX])	[PASS/FAIL]	Includes [CRITICAL_THRESHOLD] (e.g., 5% error rate).
2.4.5	Agent logs retained for [LOG_RETENTION_PERIOD]	Retention policy	[PASS/FAIL]	Stored in: [LOG_STORAGE].

2.5 AGENT LIFECYCLE MANAGEMENT

Item	Requirement	Evidence Required	Pass/Fail	Notes
2.5.1	Onboarding checklist completed	[ONBOARDING_CHECKLIST]	[PASS/FAIL]	Includes [STEPS (e.g., "Test in sandbox")].
2.5.2	Deprecation process defined	[DEPRECATION_PROTOCOL]	[PASS/FAIL]	Notifies: [STAKEHOLDER_EMAILS].
2.5.3	Version control for agent code/config	Git commit history or [VERSION_TRACKING_SYSTEM]	[PASS/FAIL]	Latest version: [VERSION_NUMBER].
2.5.4	Dependency updates monitored	[UPDATE_MONITORING_TOOL]	[PASS/FAIL]	Alerts for [CRITICAL_DEPENDENCIES].
2.5.5	Audit trail maintained for all changes	Sample audit log	[PASS/FAIL]	Includes [CHANGE_TYPE (e.g., "Permission update")].

3. ADOPTION NOTES

Field	Description	Owner	Documentation Source
[ORGANIZATION NAME]	Name of the organization undergoing audit.	[AUDIT TEAM]	[ORGANIZATION DOCUMENTATION]
[EFFECTIVE DATE]	Date this template was applied.	[AUDITOR]	Audit log.
[AUDIT TEAM NAME]	Team conducting the audit.	[TEAM_LEAD]	[TEAM DIRECTORY]
[REQUESTER'S MANAGER]	Manager approving the grant request.	[MANAGER_ROLE]	[ORGANIZATION CHART]
[USE-CASE DESCRIPTION]	Justification for the AI agent's purpose.	[REQUESTER]	[PROJECT DOCUMENTATION]
[AGENT_ROLE]	RBAC role assigned to the agent.	[SECURITY_TEAM]	[RBAC POLICY]
[PERMISSION_LIST]	List of permissions granted.	[SYSTEM_ADMIN]	[PERMISSION MATRIX]
[POLICY DOCUMENT LINK]	Link to the AI Governance Policy.	[LEGAL_TEAM]	[INTRANET]
[GRANT_EXPIRY_DATE]	Date the grant automatically revokes.	[AUDIT TEAM]	[GRANT MANAGEMENT SYSTEM]
[BUDGET_AMOUNT]	Allocated budget for the agent.	[FINANCE_TEAM]	[BUDGET APPROVAL]

Field	Description	Owner	Documentation Source
[COST_ALERT_THRES HOLD]	Percentage over budget to trigger alerts.	[FINANCE_APPROVER]	[COST POLICY]
[QUOTA_LIMIT]	Maximum API calls per day.	[SYSTEM_ADMIN]	[API DOCUMENTATION]
[LOG_RETENTION_PE RIOD]	How long logs are stored.	[DATA_ARCHIVE_TEA M]	[RETENTION POLICY]
[PLAYBOOK_LINK]	Link to the incident response playbook.	[SECURITY_TEAM]	[SECURITY PORTAL]
[CONTAINMENT_PRO CEDURE]	Steps to contain a breach.	[INCIDENT_RESPONS E_TEAM]	[SECURITY PROCEDURES]
[ONBOARDING_CHEC KLIST]	Steps completed during onboarding.	[AGENT_OWNER]	[ONBOARDING DOCS]
[DEPRECATION			

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com